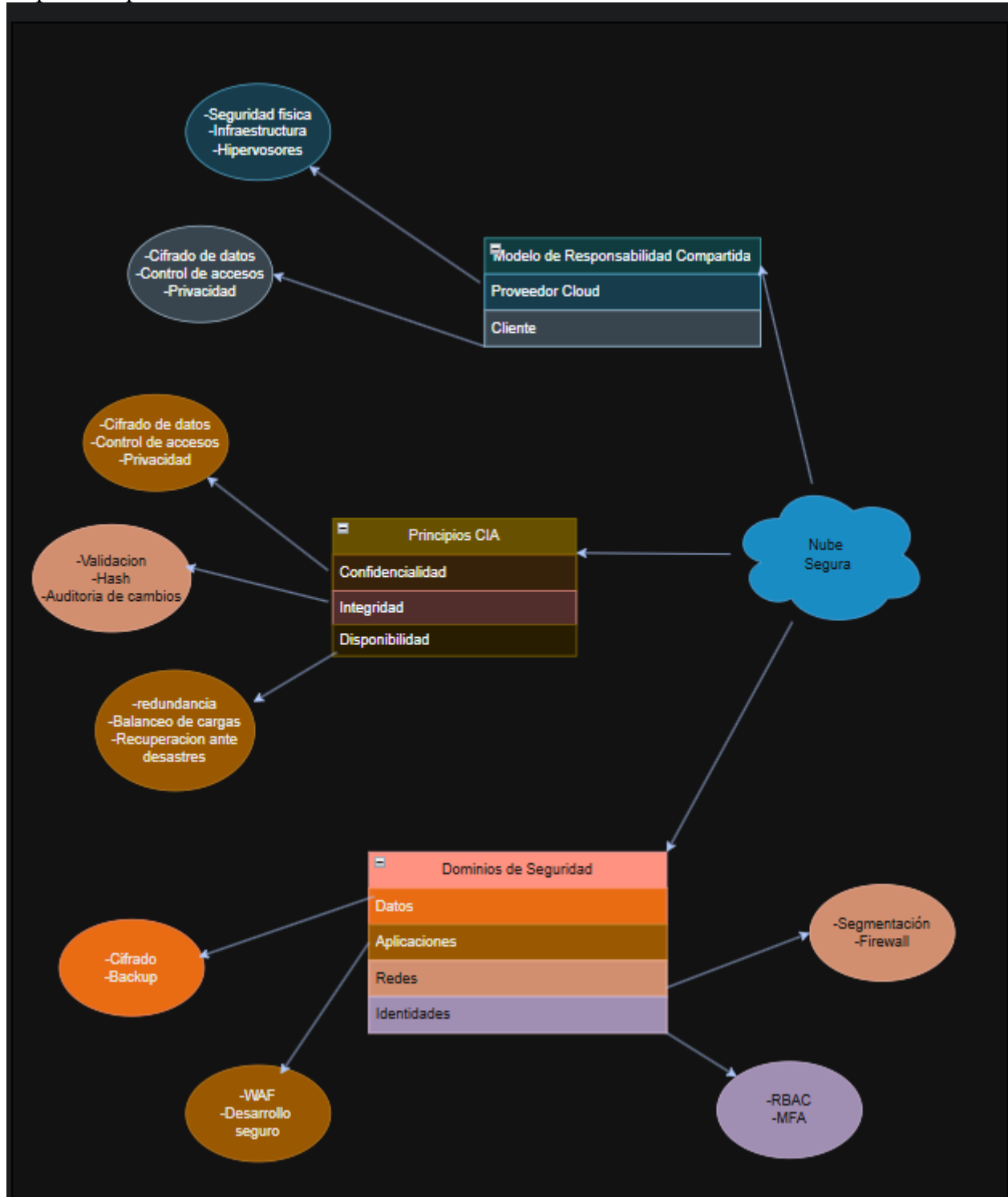


1.-Conceptos básicos de seguridad en la nube

a) Mapa conceptual



b) Resumen técnico con los beneficios, desafíos y dominios de seguridad

La seguridad en la nube se sustenta en los principios de confidencialidad, integridad y disponibilidad (CIA), que garantizan la protección de los activos digitales frente a amenazas internas y externas. En

este entorno, el modelo de responsabilidad compartida define los límites entre las obligaciones del proveedor de servicios cloud y las del cliente, estableciendo una colaboración esencial para mantener la seguridad y el cumplimiento normativo

Beneficios:

- escalabilidad y elasticidad: permite ajustar recursos según demanda sin comprometer la seguridad
- reducción de costos: elimina infraestructura física y optimiza mantenimiento
- alta disponibilidad: redundancia geográfica y balanceo de carga aseguran continuidad del servicio
- automatización y monitoreo: herramientas nativas de los proveedores facilitan auditorías y respuesta ante incidentes
- cumplimiento normativo simplificado: muchos proveedores integran estándares como ISO27001, GDPR o NIST.

Desafíos:

- visibilidad limitada: el cliente depende del proveedor para conocer el estado de la infraestructura
- gestión de recursos: errores en permisos o privilegios excesivos pueden generar brechas
- configuraciones inseguras: recursos mal configurados (por ejemplo: buckets públicos) exponen datos sensibles
- cumplimiento legal: las leyes de protección de datos varían según jurisdicción y tipo de información
- dependencia del proveedor: la seguridad física y de infraestructura está fuera de control directo del cliente

Dominios de seguridad en la nube

Dominio	Objetivo principal	Controles recomendados
Datos	Proteger información en tránsito y reposo	Cifrado AES-256, backup automatizado, gestión de claves
Aplicaciones	Fortificar código y entorno de ejecución	WAF, validación de entradas, pruebas OWASP
Identidades y accesos	Garantizar autenticación y autorización seguras	RBAC, MFA, federación de identidades
Redes virtuales	Asegurar comunicación interna y externa	Segmentación, firewalls, IDS/IPS
Cumplimiento y auditoría	Mantener trazabilidad y conformidad	Logs centralizados, SIEM, reportes de cumplimiento

c) Riesgos clave al adoptar nubes públicas, privadas e híbridas

Nube pública

- exposición de datos sensibles: mayor superficie de ataque al estar en infraestructura compartida
- dependencia del proveedor: el cliente tiene menos control sobre la seguridad física y lógica
- cumplimiento normativo complejo: riesgo de incumplir obligaciones como GDPR o HIPAA si los datos se almacenan en jurisdicciones distintas
- ataques externos más frecuentes: entornos públicos suelen ser objetivo de DDoS, phishing y explotación de configuraciones inseguras

Nube privada:

costos elevados: infraestructura dedicada requiere inversión significativa en hardware y personal especializado

-errores de configuración interna: la responsabilidad recae totalmente en el equipo de TI de la organización

-menor elasticidad: escalabilidad limitada frente a picos de demanda

-riesgo de aislamiento insuficiente: si la visualización no está bien gestionada, puede haber fugas de datos entre entornos internos

Nube híbrida:

-complejidad en la Interoperatividad: integrar políticas de seguridad entre entornos públicos y privados puede generar inconsistencias

-vectores de ataque cruzados: un fallo en la nube pública puede comprometer la privada si no hay segmentación adecuada

-gestión de identidades dispersa: riesgo de duplicación o incoherencia en permisos y roles entre plataformas

-monitoreo fragmentado: dificultad para mantener visibilidad y trazabilidad en múltiples entornos.

2.-Cumplimiento y legislación en la nube

a) Normativas legales relevantes y su impacto

GDPR (general data protection regulation – UE)

-impacto: obliga a proteger datos personales de ciudadanos europeos, garantizando derechos como acceso, rectificación y eliminación

-relevancia en cloud: exige cifrado, consentimiento explícito y notificación de incidentes en menos de 72 horas

ISO/IEC 27001

-impacto: establece un sistema de gestión de seguridad de la información (SGSI) con controles estandarizados

-relevancia en cloud: asegura que el proveedor implemente políticas, auditorías y controles de seguridad certificados

HIPAA (health insurance portability and accountability act- EE.UU.)

-impacto: regula la protección de datos clínicos y de salud

-relevancia en cloud: obliga a cifrado, control de accesos y acuerdos de confidencialidad con proveedores que procesan datos médicos

b) Simulación de contrato de servicio (SLA + privacidad)

contrato de servicio cloud – innovaCloud & proveedor X

-disponibilidad garantizada: 99% mensual

-privacidad de datos: el proveedor se compromete a cifrar datos en tránsito y reposo, y a no compartir información con terceros sin autorización

-notificación de incidentes: máximo 72 horas tras detección

-responsabilidad compartida:

proveedor: infraestructura física, seguridad de red e hipervisores

cliente: configuración de accesos, gestión de usuarios y protección de aplicaciones

-cláusula de rescisión: el cliente puede finalizar el contrato si se incumplen los SLA por más de 3 meses consecutivos

c) responsabilidades según modelo de servicio

Modelo	Proveedor	Cliente
IaaS	Infraestructura física, virtualización, almacenamiento y red	Configuración de SO, aplicaciones, datos y accesos
PaaS	Infraestructura, sistema operativo y middleware	Desarrollo y gestión de aplicaciones, datos y accesos
SaaS	Infraestructura, plataforma y aplicaciones completas	Configuración de usuarios, gestión de accesos y uso seguro de la aplicación

3.- Seguridad de aplicaciones en la nube

a) Checklist de desarrollo seguro

Comunicación segura

- uso obligatorio de HTTPS/TLS 1.2 o superior
- certificados digitales válidos y renovados

Validación de entradas

- sanitización de datos de usuario
- uso de parámetros preparados en consultas SQL
- rechazo de caracteres peligrosos en formularios

Almacén seguro

- hash para contraseñas (ej: bcrypt, Argon2)
- cifrado AES-256 para datos sensibles
- gestión segura de claves (KMS)

Gestión de sesiones

- tokens de sesión con expiración
- cookies seguras (secure más HttpOnly)
- protección contra CSRF

Monitoreo y auditoría

- logs centralizados
- alertas ante intentos de acceso sospechosos

b) configuración segura para una aplicación en la nube

WAF genérico (Web Application Firewall)

- filtrado de tráfico HTTP/HTTPS
- reglas contra ataques OWASP top 10 (SQLi, XSS, CSRF)
- bloqueo de IPs maliciosas y limitación de peticiones

CDN (Content Delivery Network)

- distribución de contenido en múltiples nodos para mejorar la disponibilidad
- mitigación de ataque DDoS
- cache de contenido estático para reducir carga en servidores

Integración adicional

- escaneo continuo de vulnerabilidades
- actualización automática de parches

c) Simulación de medidas contra ataques de inyección SQL y XSS en un formulario de login escenario:

la aplicación web de SecureCloud dispone de un formulario de autenticación donde los usuarios ingresan: correo electrónico o nombre de usuario y contraseña.

Este formulario debe protegerse frente a ataques comunes como SQL Inyección (SQLi) y Cross-Site Scripting (XSS)

Protección contra Inyección SQL (SQL Injection)

un atacante podría ingresar el valor ' OR '1'='1', la consulta resultante podría ser "SELECT * FROM usuarios WHERE usuario = ' OR '1'='1' AND password = '";" esto podría permitir el acceso sin conocer credenciales válidas

Medidas de mitigación:

-uso de consultas parametrizadas, en lugar de concatenar datos de usuario

ejemplo:

```
cursor.execute(
```

```
2
```

```
"SELECT * FROM usuarios WHERE usuario = ? AND password = ?",
```

```
3
```

```
(usuario, password)
```

```
4
```

```
)
```

beneficio, la base de datos interpreta los parámetros como datos y no como instrucciones SQL

Validación de entradas

permitir solo los caracteres esperados

```
1  Usuario:
2
3  - Letras
4
5  - Números
6
7  - Correo electrónico
8
9  Longitud máxima: 50 caracteres
10
```

ejemplo:

```
11
12
13
14  ^[a-zA-Z0-9@._-]{3,50}$
15
16
```

Principio de mínimo privilegio, la cuenta utilizada por la aplicación debe tener solo permisos de lectura y escritura necesarios

```
14
15  ✓ SELECT
16
17  ✓ INSERT
18
19  ✓ UPDATE
20
21  ✗ DROP
22
23  ✗ ALTER
24
25  ✗ CREATE
26
```

Monitoreo y alertas, detectar intentos repetitivos que incluyan patrones sospechosos

```
27
28  '
29
30  --
31
32  OR 1=1
33
34  UNION SELECT
35
```

Protección contra Cross-Site Scripting (XSS)

ejemplo de ataque, un atacante introduce en un formulario

```
1
2  <script>alert('Ataque XSS')</script>
3  ``
4  |  |  |  ``
```

si la aplicación muestra directamente el contenido

```
6
7  Bienvenido,
8
9  <script>alert('Ataque XSS')</script>
10
11
```

```
http://127.0.0.1:3000/e/tareasbotcampFundamentos/pro
`` `` Bienvenido,
```

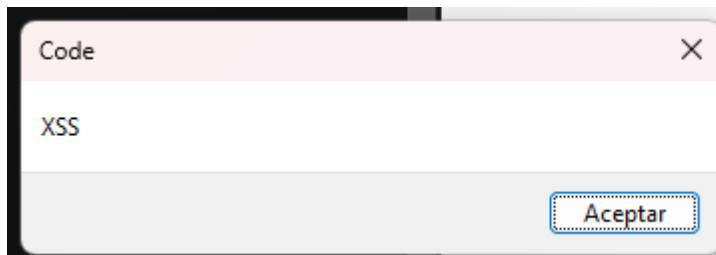
el navegador ejecutara código malicioso

Medidas de mitigación

sanitización de entradas, eliminar etiquetas HTML peligrosas
entrada

```
E: > tareasBotcampFundamentos > proyecto > <> prueba
1  <script>alert('XSS')</script>
2
3
```

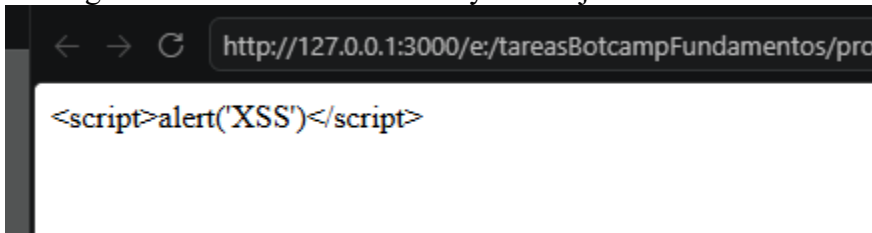
resultado



Escape de caracteres especiales, convertir caracteres HTML a entidades seguras

```
E: > tareasBotcampFundamentos > proyecto > <> prueba.html
1  &lt;script&gt;alert('XSS')&lt;/script&gt;
2
3
```

el navegador lo mostrara como texto y no lo ejecutara



Implementar Content Security Policy (CSP)

```
1  Content-Security-Policy:
2
3  default-src 'self';
4
5  script-src 'self';
6
7  object-src 'none';
8
```

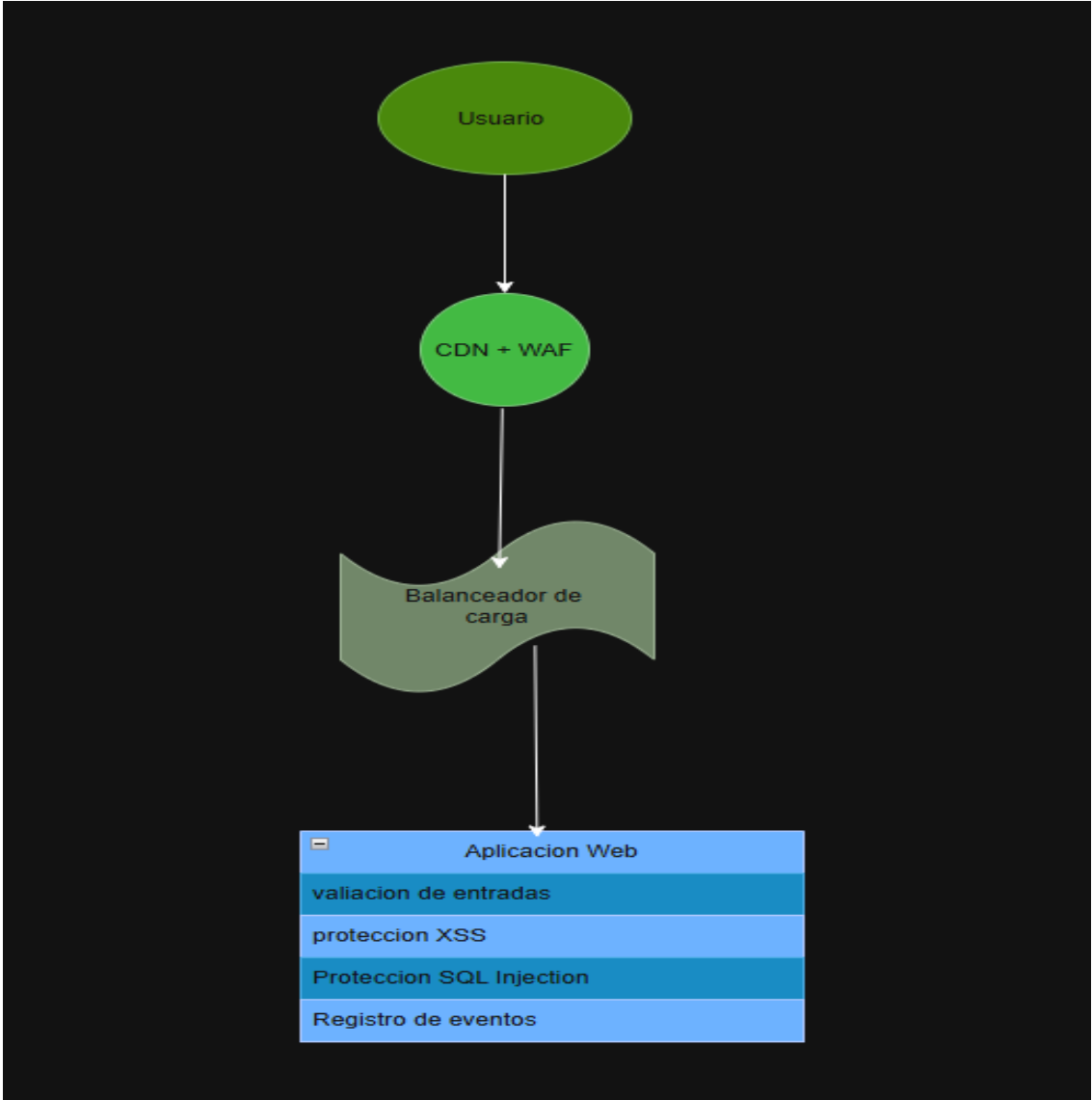
esta política impide la ejecución de scripts externos no autorizados

Uso de cookies seguras

```
1 HttpOnly
2
3 Secure
4
5 SameSite=Strict
```

- Beneficios:
- evita robo de cookies mediante JavaScript
 - solo permite transmisión por HTTPS

-reduce ataques de secuestro de sesión
Configuración segura del login



esperado

Resultado

Amenaza	Control implementado
SQL Injection	Consultas parametrizadas
SQL injection	Validación de entradas
SQL injection	Mínimos privilegios en BD
XSS	Sanitización de entradas
XSS	Escape de caracteres HTML

XSS	Content Security Policy (CSP)
Robo de sesión	Cookies HttpOnly Secure
Ataques automatizados	WAF y monitoreo continuo

4.-Lección 4: Gestión de identidades y accesos en la nube

a) política de control de acceso basada en roles

El modelo RBAC (Role-Based access Control) asigna permisos a roles específicos y posteriormente los usuarios heredan dichos permisos según su función dentro de la organización

Roles propuestos para SecureCloud

Rol	Responsabilidades	Permisos
Administrador TI	Gestión completa de la infraestructura	Crear, modificar y eliminar usuarios; administrar recursos y políticas
Analista de seguridad	Supervisión y monitoreo de seguridad	Acceso a registros, auditorías y reportes de seguridad
Jefe de área	Gestión de su departamento	Aprobar solicitudes y consultar información de su área
Empleado	Uso de recursos corporativos	Acceso a aplicaciones y datos autorizados
visitante/proveedor	Acceso temporal	Acceso limitado a recursos específicos

Principios de seguridad aplicados

-mínimo privilegio

cada usuario recibe únicamente los permisos necesarios para realizar sus tareas

-separación de funciones

las tareas críticas se distribuyen entre distintos roles para evitar abusos o errores

-acceso basado en necesidad

los permisos se asignan según las responsabilidades laborales

-auditoria continua

todas las acciones relevantes son registradas y monitoreadas

b) Simulación de configuración de MFA con identidades federadas

escenario ficticio para SecureCloud

la empresa utiliza:

-Microsoft Entra ID (Azure AD) como proveedor de identidad

-aplicaciones SaaS (Microsoft 365, Salesforce y AWS)

-autenticación multifactor (MFA)

-federación mediante SAML 2.0 u OpenID Connect

Flujo de autenticación

paso 1: inicio de sesión

el usuario intenta acceder a una aplicación corporativa

paso 2: redirección

la aplicación redirige la autenticación hacia Microsoft Entra ID

paso 3: verificación de credenciales

el usuario ingresa:

- usuario

- contraseña

paso 4: activación de MFA

el sistema solicita un segundo factor

- aplicación Microsoft Authenticator

- código SMS

- llave de seguridad FIDO2

- notificación push

paso 5: generación del token

tras validar ambos factores, Entra ID genera un token seguro

paso 6: acceso federado

la aplicación recibe el token y concede acceso sin requerir nuevas credenciales

Beneficios

- mayor protección frente al robo de contraseñas

- inicio de sesión único (SSO)

- gestión centralizada de identidades

- reducción de riesgos de accesos no autorizados

c) Arquitectura lógica del sistema de gestión de identidades y accesos

Diagrama Lógico

Componentes del diagrama:

usuario: persona que solicita acceso a recursos corporativos

portal de inicio de sesión: punto central para autenticarse

Microsoft Entra ID: proveedor de identidad encargado de validar usuarios y emitir tokens de acceso

Servicio MFA: implementa una segunda capa de autenticación

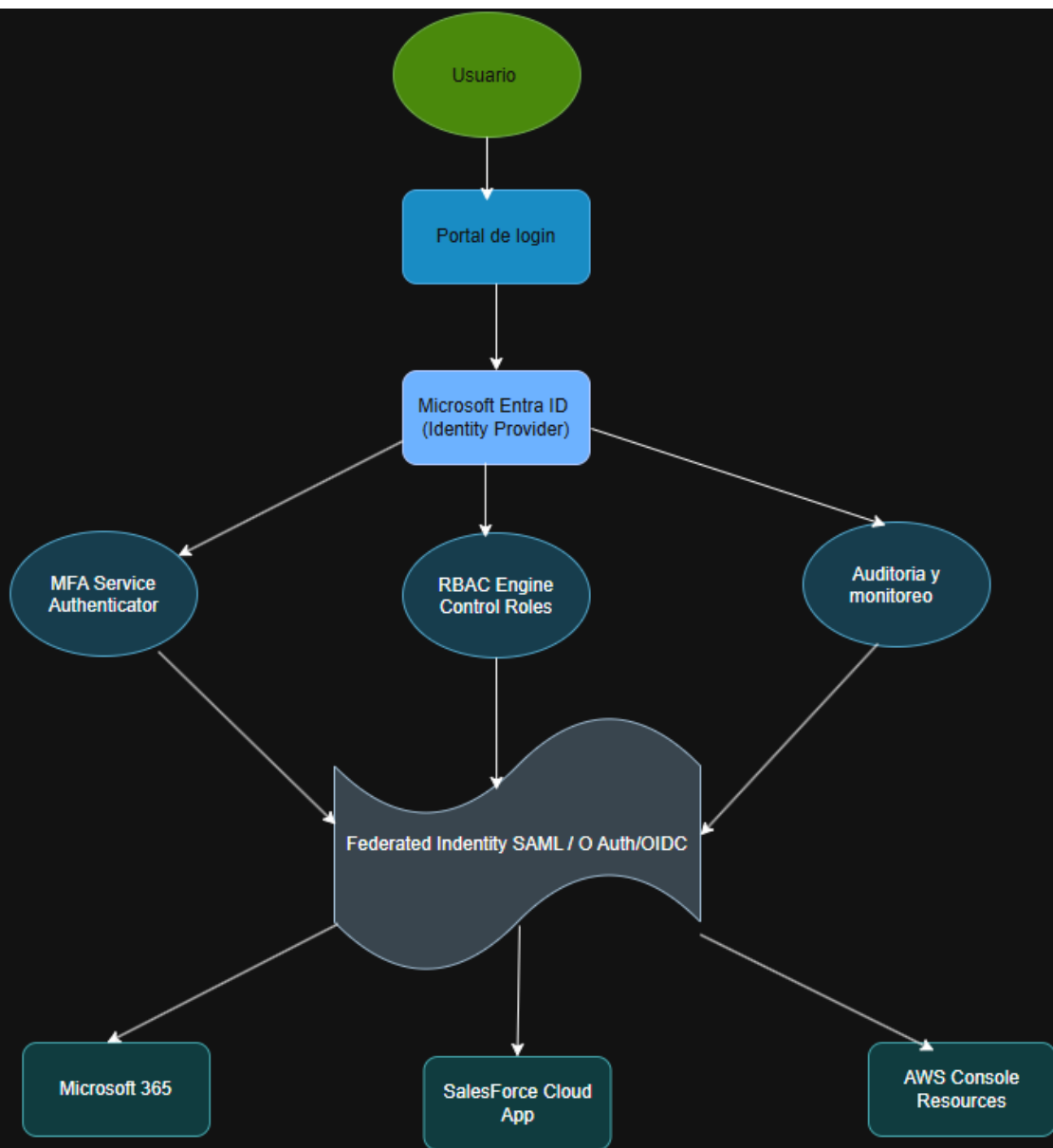
Motor RBAC: valida los permisos asociados a cada rol

federación de identidades: permite acceso seguro a multitud de aplicaciones usando una única identidad

auditoría y monitoreo: registra eventos de acceso, cambios de permisos y actividades sospechosas

aplicaciones y recursos: servicios en la nube que consumen identidad validada

La implementación conjunta de RBAC, MFA e identidades federadas permite construir un sistema de gestión de identidades y accesos seguro, escalable y alineado con las mejores prácticas de ciberseguridad. Este enfoque garantiza que los usuarios accedan únicamente a los recursos necesarios, mediante autenticación reforzada y administración centralizada de credenciales y permisos

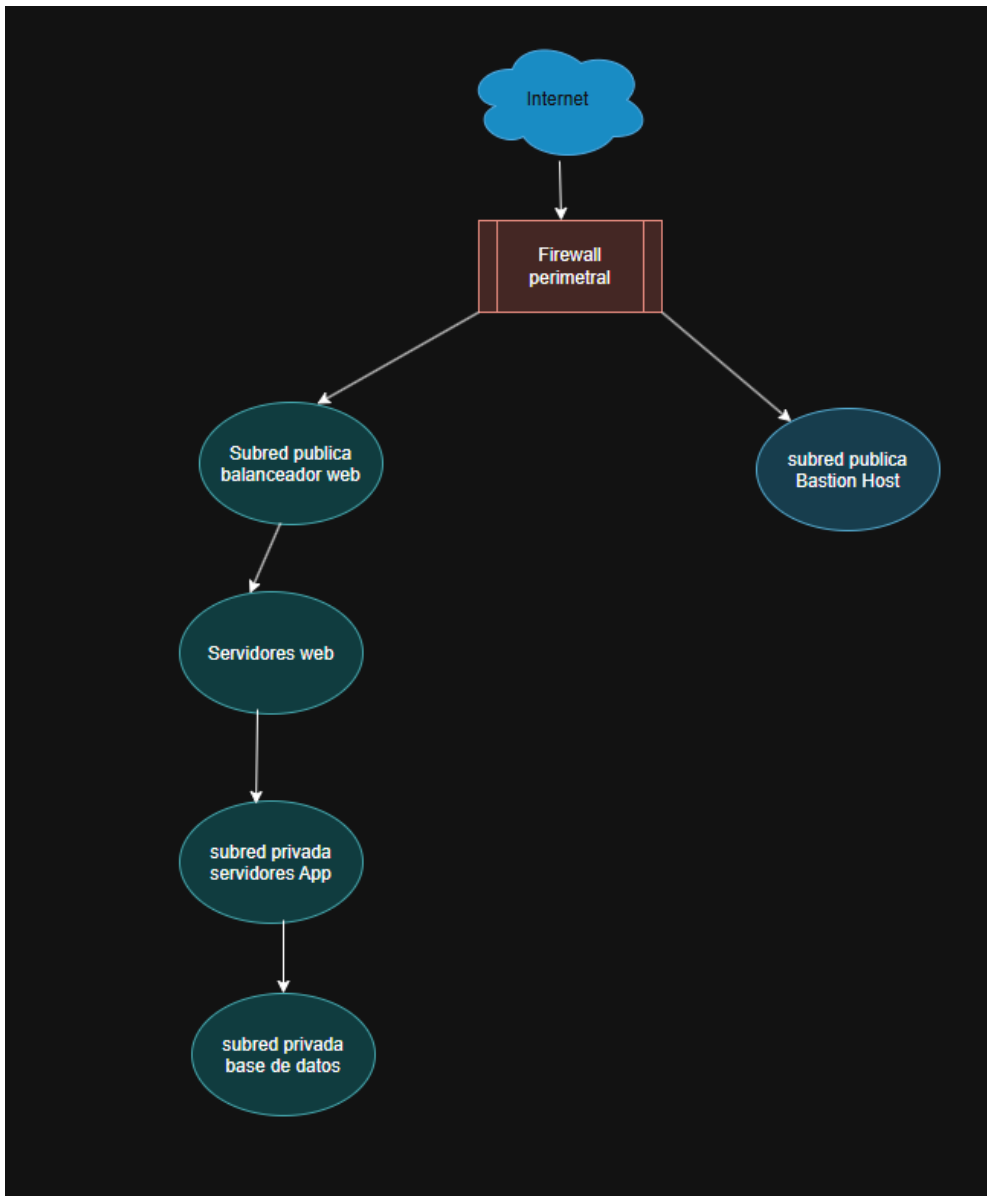


5.- seguridad de redes en la nube

a) diseñar una red virtual segmentada

Arquitectura de red virtual (VPC o Vnet) dividida en subredes públicas y privadas para aislar los recursos según su nivel de exposición a Internet

Estructura de la red



Segmentación de Subredes

Subred publica

contiene recursos accesibles desde internet

- balanceador de carga (Load Balancer)
- servidores web públicos
- bastión Host para administración segura

Subred privada de aplicaciones

contiene:

- servidores de aplicaciones
- servicios internos

- APIs corporativas
no permite acceso directo desde internet
- Subred privada de base de datos
contiene:
 - base de datos SQL y NoSQL
 - sistemas de almacenamiento críticosúnicamente recibe conexiones desde la capa de aplicaciones

Políticas de firewall

Reglas permitidas

Origen	Destino	Puerto	Acción
Internet	Balanceador web	80, 443	Permitir
Bastión Host	Servidores internos	22, 3389	Permitir
Servidores web	Servidores App	8080	Permitir
Servidores App	Base de datos	3306,54	permitir

reglas denegadas

Origen	Destino	Acción
Internet	Base de datos	Denegar
Internet	Servidores App	Denegar
Cualquier origen no autorizado	Recursos internos	denegar

principio aplicado, denegar todo por defecto (Default Deny)

b) Uso de ACL y Sistemas de detección de intrusos

Listas de control de acceso (ACL)

las ACL permiten controlar el tráfico a nivel de red mediante reglas que autorizan o bloquean paquetes

ACL para la subred web

```
E: > tareasBotcampFundamentos > proyecto > <> prueba.html
1  permitir TCP 80 desde internet
2  permitir TCP 443 desde internet
3  denegar cualquier otro trafico
4
5  #regla adicional
6  registrar intentos de acceso no autorizados
7
```

ACL para la subred de aplicaciones

```
E: > tareasBotcampFundamentos > proyecto > <> prueba.html
1  permitir TCP 8080 desde subred Web
2  denegar trafico desde internet
3
4
5
```

ACL para base de datos

```
E: > tareasBotcampFundamentos > proyecto > <> prueba.html
1  permitir TCP 3306 desde subred aplicaciones
2  permitir TCP 5432 desde subred aplicaciones
3  denegar cualquier acceso externo
4
5
6
```

Sistema de detección de intrusos (IDS)

funciones

- monitoreo continuo del trafico
- identificación de actividades sospechosas
- detección de ataques conocidos
- generación de alertas en tiempo real

Eventos detectables

- escaneo de puertos
- ataques de fuerza bruta
- tráfico anómalo
- intentos de explotación de vulnerabilidades

Herramientas recomendadas

- Snort
- Suricata
- Azure Network Watcher
- AWS GuardDuty
- Goggle Cloud IDS

Sistema de prevención de intrusos (IPS)

Ademas del IDS, se recomienda implementar IPS para:

- bloquear automáticamente amenazas
- detener conexiones maliciosas
- aplicar respuestas automáticas ante incidentes

c) Buenas prácticas para evitar la exposición innecesarias de servicios

Acceso remoto seguro

- utilizar VPN para administración remota
- restringir SSH (22) y RDP (3389) a direcciones IP autorizadas
- implementar autenticación multifactor (MFA)

Principio de mínimo acceso

- conceder únicamente los permisos necesarios
- revisar periódicamente reglas de red y accesos
- eliminar accesos temporales una vez finalizada la tarea

Protección de servicios

- utilizar HTTPS/TLS en todas las aplicaciones

- deshabilitar puertos y servicios innecesarios
- mantener sistemas actualizados con parches de seguridad
- aplicar cifrado de datos en tránsito y en reposo

Monitoreo y registro

- habilitar logs de firewall
- configurar alertas automáticas ante comportamientos sospechosos
- centralizar registros en una plataforma SIEM
- revisar eventos de seguridad periódicamente

Segmentación de red

- separar entornos de producción, pruebas y desarrollo
- aislar bases de datos en subredes privadas
- evitar que recursos críticos tengan acceso directo a internet

En conclusión, una arquitectura segura en la nube debe apoyarse en la segmentación de subredes, el uso de firewalls, ACL, sistemas de IDS/IPS y la aplicación de buenas prácticas de administración, estas medidas reducen significativamente la superficie de ataque, permiten un mejor control de tráfico y fortalecen la protección de los recursos críticos de la organización